

Security Checklist

(To be completed prior to deployment and on code revision)

Project Information

Field	Detail	Field	Detail
Project Name:	CIPD 360 ERP (Next.js & Supabase)	Academic Term:	Summer 2026
Location / Dept:	IIIT Delhi / CIPD Lab	Students:	Priyanshu, Parsh, Aaman
Date of Audit:	June 18, 2026	Time of Audit:	12:50 PM

ITEMS TO BE CHECKED

#	ITEMS TO BE CHECKED	YES (☒)	NO (☐)	N/A (☐)	COMMENTS / REMEDIATION ACTIONS
1	Supabase Service Key Security Verify Supabase service key is not hardcoded in Python script.	[☒]	[☐]	[☐]	Fixed: Removed from <code>wifi_monitor.py</code> ; now loaded via runtime environment (<code>.env</code>).
2	Router Admin Password Security Verify WiFi router login password is not hardcoded.	[☒]	[☐]	[☐]	Fixed: Migrated router login string to environment configs.
3	Frontend Key Injection Check Verify frontend login files do not check passwords client-side.	[☒]	[☐]	[☐]	Fixed: Removed administrative password match from <code>page.jsx</code> .
4	Demo Credentials Protection Verify credentials arrays are removed from browser JS bundles.	[☒]	[☐]	[☐]	Fixed: Completely deleted the demo accounts panel and array from <code>page.jsx</code> .
5	Environment Config Exclusion Verify local <code>.env</code> and <code>.env.local</code> files are git-ignored.	[☒]	[☐]	[☐]	Fixed: Configured in <code>.gitignore</code> to prevent accidental commits.
6	JWT Secret Fallback Restriction Verify JWT signer throws exceptions if env key is missing.	[☒]	[☐]	[☐]	Fixed: Hardcoded fallback string removed from <code>lib/auth.js</code> ; throws on start.
7	OAuth State CSRF Integrity Verify Google OAuth state parameter is signed and authenticated.	[☒]	[☐]	[☐]	Fixed: Implemented HMAC-SHA256 signer in <code>connect/route.js</code> and verified callback state using constant-time <code>timingSafeEqual</code> .
8	Cron Job Secret Fallback Restriction Verify Cron processing endpoints assert env secrets strictly.	[☒]	[☐]	[☐]	Fixed: Removed developer fallback secret in <code>process-attendance/route.js</code> ; returns 401 on unauthorized hits.
9	HttpOnly Cookie Token Storage Verify authentication JWTs are stored in HttpOnly cookies (not localStorage).	[☐]	[☒]	[☐]	<i>Planned:</i> Tokens stored in localStorage per role (<code>student_token</code> , etc.) are vulnerable to XSS. Need migration to HttpOnly.

#	ITEMS TO BE CHECKED	YES ()	NO ()	N/A ()	COMMENTS / REMEDIATION ACTIONS
10	Session Lifetime Constraints Verify tokens have short expiry limits and account revocation checks.	☐	☒	☐	<i>Planned:</i> JWT tokens valid for 7 days without server-side revocation mechanism in place.
11	Login Endpoint Rate Limiting Verify protection against credential stuffing / brute-force on login.	☐	☒	☐	<i>Planned:</i> Rate limiter or CAPTCHA middleware needed for <code>/api/auth/login</code> .
12	HTTP Security Headers Verify presence of HSTS, CSP, X-Frame-Options, X-Content-Type.	☐	☒	☐	<i>Planned:</i> Populate config headers in <code>next.config.js</code> before launch.
13	User Self-Registration Restrictions Verify domain-matching or administrative sign-up approvals.	☐	☒	☐	<i>Planned:</i> Open student self-registration flow needs email verification or invite mechanism.
14	API Search Input Parameter Bounds Verify query inputs enforce strict length/pattern matching checks.	☐	☒	☐	<i>Planned:</i> Cap size of queries and sanitize character inputs in search routes to prevent DoS.
15	API Pagination Size Constraints Verify <code>pageSize</code> parameters are capped to prevent DB resource exhaustion.	☐	☒	☐	<i>Planned:</i> API router files need explicit validation logic (<code>Math.min(pageSize, 500)</code>).
16	Supabase Row-Level Security (RLS) Verify DB tables enforce authenticated tenant data isolation.	☐	☒	☐	<i>Planned:</i> Must ensure table policies are enabled inside Supabase dashboard for any non-admin connections.
17	OAuth Access Token Cryptography Verify Google Access and Refresh tokens are encrypted at rest.	☐	☒	☐	<i>Planned:</i> Google Tokens table currently logs plaintext values in database.
18	Information Leakage Prevention Verify raw DB exception stack traces are suppressed in API responses.	☐	☒	☐	<i>Planned:</i> Catch clauses in backend need custom user-facing generic messages.
19	WiFi Scraper HTTPS Protocol Verify Selenium driver connects to router admin page over TLS.	☐	☐	☒	<i>N/A:</i> Physical router admin panel does not support HTTPS (connection is isolated or intranet LAN).
20	WiFi Driver Exception Bypass Verify browser does not bypass certificate warnings blindly.	☐	☒	☐	<i>Planned:</i> Remove general <code>--ignore-certificate-errors</code> flag and pin exact fingerprint if necessary.
21	Scan Service Least Privilege Verify automated scraping service runs under low-privilege system role.	☐	☒	☐	<i>Planned:</i> Windows Service currently executing script as local <code>SYSTEM</code> .
22	VCS Database Schema Cleanliness Verify database schema	☐	☒	☐	<i>Planned:</i> File <code>db.txt</code> and sql scripts should be

#	ITEMS TO BE CHECKED	YES ()	NO ()	N/A ()	COMMENTS / REMEDIATION ACTIONS
	logs are excluded from public git repo.				deleted and added to git ignore list.
23	Package Dependency Audit Verify clean audit list on dependencies (<code>npm audit</code>).	[]	[]	[]	<i>Planned:</i> Schedule dependency scan and patch versions before shipping.
24	Central Route Guards Middleware Verify presence of central <code>middleware.ts</code> for route group matching.	[]	[]	[]	<i>Planned:</i> Set up top-level Next.js route matching rules instead of page-level HOC wrappers.

Remarks

All **Critical** severity checklist items (**1 through 8**) have been successfully remediated. These changes remove direct vectors for administrative privilege escalation, database access key leaks, and Google OAuth callback state forgery.

The system is now structurally secure against immediate breach points. **Phase 2 (Hardening)** checks (**9 through 24**) are scheduled for implementation during the post-deployment sprint.

Sign-off Details

Field	Detail	Signature
Inspected By:	Parsh, Priyanshu, Aaman	_____
Reviewed By:	Course Professor / Supervisor	_____